Penetration Testing Report Template

Student Assessment Template

Student Name	[Insert your name]
Student ID	23249815
Unit	ISEC6005
Assessment Title	Final Exam Part 2 - Report
Target Machine	[Insert target Name/IP]
Date Submitted	[Insert date]

Important: This report must present findings responsibly. Include only authorised testing activity, clear evidence, impact, and remediation. Long command histories should be moved to the appendix.

REMINDER – what to put here (from the boxes you practised): Use this for an anonymous-SMB box (like Velora). [TARGET-IP] = your box IP; [SHARE-NAME] = the non-default share you find with smbclient -L (e.g. a custom share, not C$/ADMIN$/IPC$); [FILE] = the file holding the flag; [USER]/[PASSWORD] = credentials you read from a config/notes file; [REMOTE-SERVICE] = the port you log into with them (WinRM 5985 / RDP 3389 / SSH 22).

Report Sections

1. Executive Summary
2. Scope and Rules of Engagement
3. Testing Methodology
4. Summary of Findings
5. Detailed Findings
6. Attack Path Summary
7. Remediation Plan
8. Conclusion
9. Appendix A. Technical Evidence
10. Appendix B. References

1. Executive Summary

During the authorised assessment of the target host ([TARGET-IP]), the SMB service on ports 139/445 was found to expose a non-default file share ([SHARE-NAME]) that could be accessed anonymously, using a null session with no username or password. The share contained sensitive files, including one holding the flag and a configuration file that disclosed valid credentials. Those credentials were reused to authenticate to the host over [REMOTE-SERVICE e.g. WinRM 5985] and retrieve a second, higher-privilege flag. The highest risk is the anonymous share exposure (rated High). The main attack path is: anonymous SMB read → credential disclosure → authenticated access to the host. The primary root cause is a share configured to permit guest access with no authentication.

Area	Student Entry	Guidance

Overall Risk	High	Choose one overall rating and justify it briefly.
Main Impact	An unauthenticated attacker on the network can read confidential files from a shared folder, and credentials disclosed in those files allow authenticated access to the host.	Describe what could happen to the system or organisation.
Primary Root Cause	Security misconfiguration – an SMB share allows anonymous (null-session) access.	Example: misconfiguration, weak access control, exposed credentials.
Top Remediation Priority	Disable anonymous/guest access on the file share.	State what should be fixed first and why.

2. Scope and Rules of Engagement

2.1 Scope

Asset / Host	IP / URL	Service(s)	In Scope?
[TARGET-HOST e.g. Velora]	[TARGET-IP]	SMB (139/445)	Yes
[TARGET-HOST e.g. Velora]	[TARGET-IP]	[REMOTE-SERVICE e.g. WinRM 5985]	Yes

2.2 Rules of Engagement

- ☐ Testing was conducted only against authorised targets.
- ☐ Testing avoided unnecessary service disruption.
- ☐ Evidence was recorded for each finding.
- ☐ Sensitive data was handled responsibly and not disclosed unnecessarily.
- ☐ No persistence was installed unless explicitly required by the lab instructions.

3. Testing Methodology

Phase	Purpose	Evidence to Include
Reconnaissance	Confirm SMB is running on 139/445 and identify the host/OS.	`nmap -p139,445 -sV [TARGET-IP] (confirm SMB)`
Enumeration	List the shares and their permissions; find any non-default share.	`smbclient -L //[TARGET-IP]/ -N ; smbmap -H [TARGET-IP] (shares + perms)`
Vulnerability Analysis	Confirm a share allows	`A non-default share reads with`

	anonymous (null-session) access.	`-N (null session) = anonymous access`
Exploitation / Validation	Read the files on the open share to obtain the flag.	`smbclient //[TARGET-IP]/[SHARE-NAME] -N ; get [FILE]  (read flag)`
Privilege Escalation	Reuse any disclosed credentials to log into the host.	`evil-winrm -i [TARGET-IP] -u [USER] -p '[PASSWORD]' ; whoami`
Remediation Advice	Explain how to disable anonymous access and verify the fix.	`guest ok = no ; restrict anonymous = 2 ; least-privilege ACLs`

4. Summary of Findings

ID	Finding	Risk	Affected Asset	Status
F-01	Anonymous / Null-Session SMB Share Exposure	High	[TARGET-IP] (SMB)	Open
F-02	Credential Disclosure Enabling Lateral Movement	Medium	[TARGET-IP]	Open

REMINDER (Summary of Findings): Example for this box: F-01 = Anonymous / Null-Session SMB Share Exposure (High). Add F-02 = Credential Disclosure Enabling Lateral Movement only if you also reached the intermediate flag; delete the unused F-03–F-05 rows.

5. Detailed Findings

REMINDER (Detailed Findings): Example for this box: Finding 1 = Anonymous / Null-Session SMB Share Exposure. Replace the Evidence block with YOUR own command output / screenshots. Keep Finding 2 (Credential Disclosure Enabling Lateral Movement) only if you reached the intermediate flag by reusing credentials – otherwise delete it.

Finding 1: Anonymous / Null-Session SMB Share Exposure

Risk Rating	High
Affected Asset(s)	[TARGET-IP], SMB share [SHARE-NAME] (ports 139/445)
Vulnerability Type	Security misconfiguration – anonymous share access (broken access control)
Evidence Reference	E-01, E-02
Business Impact	An attacker can read all files on the share, including credentials, and use them to access the host.
Remediation Priority	Immediate

Description

The host exposes a non-default SMB share ([SHARE-NAME]) that permits anonymous, null-session access: no credentials are required to connect and read its files. Enumeration listed the share and confirmed read access, and the share held sensitive files including the flag and a configuration file containing credentials. The weakness is that guest/anonymous access was left enabled on a share holding sensitive data, so confidentiality depends on obscurity rather than authentication. (On exam day, change [TARGET-IP], the share name, and the file names to what you find – the explanation of the weakness stays the same.)

Evidence

```
nmap -p139,445 -sV [TARGET-IP]            # confirm SMB service + version
smbclient -L //[TARGET-IP]/ -N            # list shares -> [SHARE-NAME] (non-default)
smbmap -H [TARGET-IP]                      # shows READ access on [SHARE-NAME]
smbclient //[TARGET-IP]/[SHARE-NAME] -N   # connect with a null session
smb: \> ls ; get [FILE]                    # retrieve the sensitive file
```

Impact

Any user who can reach the service can read every file on the share – not only the flag but documents, backups, scripts and, as here, a credential file. The disclosed credentials provided authenticated access to the host, turning an information-disclosure issue into interactive access and lateral movement. In business terms this is unauthorised disclosure of confidential data and a realistic path to full host compromise.

Recommendation

Disable guest/anonymous access on the share (guest ok = no); set restrict anonymous = 2 on Windows to prevent null-session enumeration; apply least-privilege share and NTFS permissions so only named accounts can read; remove sensitive files from the share; disable SMBv1; and segment the network so the service is not broadly reachable.

Verification After Fix

Re-attempt the null-session connection (smbclient //[TARGET-IP]/[SHARE-NAME] -N) – it should be denied (NT_STATUS_ACCESS_DENIED) – and confirm the share now requires valid credentials.

Finding 2: Credential Disclosure Enabling Lateral Movement

Risk Rating	Medium
Affected Asset(s)	[TARGET-IP], [REMOTE-SERVICE e.g. WinRM 5985]
Vulnerability Type	Credential reuse / weak credential management
Evidence Reference	E-03
Business Impact	Disclosed credentials give authenticated access to the host.
Remediation Priority	Short-term

Description

Credentials found in a file on the anonymous share were valid for a remote-management service ([REMOTE-SERVICE e.g. WinRM 5985 / SSH 22 / RDP 3389]), allowing authenticated access and retrieval of a further flag. The weakness is plaintext credentials stored in a readable location combined with credential reuse across services. (Remove this finding if your box only yields the easy flag.)

Evidence

```
evil-winrm -i [TARGET-IP] -u [USER] -p '[PASSWORD]'   # authenticated shell
whoami                                                 # confirm the account
type C:\Users\[USER]\Desktop\flag.txt                 # higher-privilege flag
```

Impact

A credential left on a readable share became interactive host access, showing how one exposed secret undermines otherwise separate services and enables lateral movement.

Recommendation

Never store plaintext credentials on shares; rotate the exposed credentials; prohibit credential reuse across services; and store secrets in a managed vault.

Verification After Fix

Confirm the old credentials no longer authenticate after rotation.

6. Attack Path Summary

Step	Evidence	Security Meaning
Initial access / foothold	smbclient //[TARGET-IP]/[SHARE-NAME] -N	A null session granted read access to the share with no credentials.
Local enumeration	ls on the share; get [FILE]	Reading the share revealed the flag and a file containing credentials.
Credential or configuration weakness	cat [CONFIG-FILE]	Plaintext credentials were disclosed and were valid for a remote service.
Service or application abuse	evil-winrm/ssh/rdp with the credentials	The reused credentials gave authenticated access to the host.

Privilege escalation proof	whoami as [USER]	Confirmed authenticated access and retrieval of the higher-privilege flag.
Final impact	–	Confidential data disclosed and interactive host access obtained.

Attack Path Diagram

Anonymous SMB share read → credential file disclosed → authenticated access via [REMOTE-SERVICE] → host flag read.

7. Remediation Plan

Priority	Finding ID	Recommended Action	Owner	Verification Method
Immediate	F-01	Disable anonymous/guest access on the share and remove sensitive files from it.	Infrastructure team	Re-test that the null session is denied.
Short-term	F-02	Rotate the disclosed credentials; set restrict anonymous = 2; apply least-privilege share/NTFS ACLs.	Infrastructure team	Confirm old credentials fail and the share requires authentication.
Long-term	–	Disable SMBv1, segment the network, and enable share-access logging.	Security team	Periodic configuration review.

8. Conclusion

The assessment confirmed and fully validated an attack path from an anonymous SMB share to authenticated host access. The primary issue (anonymous share exposure) and the resulting

credential disclosure are both remediable through authentication and least-privilege controls. All testing stayed within the authorised scope and no data was altered or destroyed.

Appendix A. Technical Evidence

Use this appendix for detailed command output, screenshots, and supporting notes. Keep the main report concise.

Evidence ID	Command / Source	Screenshot / Output	Purpose
E-01	nmap -p139,445 -sV [TARGET-IP]	[screenshot]	Confirms the SMB service and version.
E-02	smbclient //[TARGET-IP]/[SHARE-NAME] -N ; ls	[screenshot]	Shows anonymous read access to the share.
E-03	evil-winrm -i [TARGET-IP] -u [USER]	[screenshot]	Shows authenticated access using the disclosed credentials.

Appendix B. References

OWASP Web Security Testing Guide – SMB/network share testing; Microsoft documentation on SMB hardening and 'RestrictAnonymous'; CIS Benchmarks for Windows file sharing.

Student Submission Checklist

- ☐ Executive summary is written for a non-technical reader.
- ☐ Each finding includes risk, evidence, impact, and remediation.
- ☐ Screenshots are labelled and referenced in the text.
- ☐ Only authorised testing activity is included.
- ☐ Sensitive credentials are redacted unless required by assessment instructions.
- ☐ The final report is professional, concise, and free of unnecessary terminal history.